

VST-Sentry Threat Intelligence Report

VST Plugin Security Risks: DLL Hijacking, Cracked Software Malware, and Red Flag API Analysis

Report Date: April 7, 2026

Classification: Open Source Intelligence (OSINT) Compilation

Prepared for: VST-Sentry Development Project

Table of Contents

1. Executive Summary
2. The VST Framework: An Architectural Weakness
3. Attack Vector 1: DLL Hijacking and Side-Loading in DAWs
4. Attack Vector 2: Malware in Cracked / Pirated VST Software
5. Red Flag Windows API Reference Table
6. Recommendations and Mitigation Strategies
7. Sources

Executive Summary

Virtual Studio Technology (VST) plugins represent a uniquely vulnerable attack surface in the software ecosystem. Unlike browser extensions (which are sandboxed), mobile apps (which require permission grants), or standard Windows executables (which leverage code signing and SmartScreen), VST plugins execute as native DLLs loaded directly into the host Digital Audio Workstation (DAW) process with full, **unrestricted** access to the operating system. There are no framework-level sandboxing mechanisms, no mandatory code signing requirements, and no permission models.

This report identifies three primary threat categories:

1. **DLL Hijacking / Side-Loading** — Attackers exploit the Windows DLL search order to trick DAWs into loading malicious DLLs instead of legitimate plugins.
2. **Trojanized Cracked Software** — Piracy groups inject cryptocurrency miners, remote access trojans (RATs), infostealers, and ransomware into modified plugin installers and binaries.
3. **Suspicious API Usage** — Legitimate audio plugins have a narrow set of expected system API calls. The presence of networking, process injection, registry manipulation, or credential-access APIs in a VST DLL is a strong indicator of malicious intent.

This research directly informs the detection heuristics used by the VST-Sentry analysis engine.

The VST Framework: An Architectural Weakness

VST was developed by Steinberg and debuted with Cubase 3.0 in 1996. Despite two major revisions (VST2 and VST3), the fundamental loading model has remained unchanged: **plugins** are native DLLs loaded directly into the host process address space.

Why VST Plugins Are Uniquely Dangerous

Property	Browser Extensions	Mobile Apps	VST Plugins
Sandboxed	Yes	Yes	No
Permission Model	Granular	Granular	None
Code Signing Required	Yes (Chrome Web Store)	Yes (App/Play Store)	No
Filesystem Access	Restricted	Restricted	Unrestricted
Network Access	Declared	Declared	Unrestricted
Process Manipulation	Impossible	Impossible	Full Capability

As documented by security researcher SpiritSeal, "VST plugins are capable of running arbitrary code, just like any other program you run on your computer. Unlike literally every other modern 3rd party plugin framework, there are absolutely no safeguards in place to protect you." (Source: <https://spiritseal.github.io/vst-malware-musician/>)

The "Plugin Scan" Illusion

Most DAWs (Ableton Live, FL Studio, REAPER, etc.) perform a "plugin scan" on startup. This is **not** a security scan — it is a metadata discovery process that actually loads and executes the plugin DLL to read its name, manufacturer, I/O configuration, and category information. This means a malicious VST can execute its payload simply by being present in a scanned plugin directory, before the user ever intentionally loads it into a project.

Attack Vector 1: DLL Hijacking and Side-Loading in DAWs

How the Windows DLL Search Order Creates Vulnerability

When a Windows application calls `LoadLibrary("plugin.dll")` without specifying a full path, the OS searches for the DLL in a predictable sequence:

1. The directory from which the application loaded
2. `C:\Windows\System32`
3. `C:\Windows\System`
4. `C:\Windows`

5. The current working directory

6. Directories listed in the PATH environment variable

This behavior, documented extensively by Palo Alto Unit 42 (Source: <https://unit42.paloaltonetworks.com/dll-hijacking-techniques/>) and CrowdStrike (Source: <https://www.crowdstrike.com/en-us/blog/4-ways-adversaries-hijack-dlls/>), enables four distinct hijacking techniques:

1. DLL Search Order Hijacking

An attacker places a malicious DLL with the same name as a legitimate dependency in a location that is searched **before** the legitimate DLL's directory. DAWs that scan user-writable plugin directories (e.g., %AppData%\VST, custom plugin folders) are especially vulnerable, because an attacker with user-level access can write to these directories.

2. DLL Side-Loading

The most common technique observed in the wild. An attacker pairs a **legitimate signed executable** with a **malicious DLL** that the executable expects to find in its own directory. In the DAW context, this can occur when:

- A user downloads a "portable" or "cracked" DAW bundle that includes both a real executable and a weaponized dependency DLL.
- A VST installer drops a legitimate helper executable alongside a malicious DLL into the plugin directory.

Real-world example: The PDFSIDER malware campaign (January 2026) used a legitimate, validly signed PDF24 Creator executable to side-load a fake `cryptbase.dll` that established an encrypted C2 backdoor with AES-256-GCM encryption. The signed executable passed all antivirus trust checks while the malicious DLL executed undetected. (Source: <https://www.researchcurity.com/blog/article/pdfsider-malware-exploitation-of-dll-side-loading-for-av-and-edr-evasion>)

3. Phantom DLL Hijacking

Some DAWs or plugins attempt to load DLLs that simply do not exist on the target system (leftover references from older versions, optional features, etc.). An attacker can create a DLL with that phantom name and place it anywhere in the search path.

4. DLL Proxying (Advanced Stealth)

A sophisticated variant where the malicious DLL **forwards all legitimate function calls** to the real DLL while simultaneously executing malicious code. The application behaves normally, the user experiences no crashes or errors, and the malware operates silently.

As noted by Dragos in their DLL Hijacking defense whitepaper: "Using DLL hijacking, attackers can trick signed and trusted processes into loading their malicious DLL, making it appear more legitimate. Security solutions are less likely to identify the activity." (Source: https://hub.dragos.com/hubfs/116-Whitepapers/Dragos_WP_DLL_Hijacking_FINAL.pdf)

DAW-Specific Attack Surface

DAWs present an amplified DLL hijacking risk because:

- **Multiple plugin directories:** DAWs scan several user-configurable directories, many of which are user-writable.
- **Plugin loading at startup:** Automatic scanning means malicious code runs before the user takes any action.
- **Trusted context:** Processes like Ableton Live.exe or FL64.exe are trusted by EDR/AV solutions, so malicious code running within their process space may evade detection.
- **High-performance hardware targets:** Music production systems typically have powerful CPUs and GPUs, making them attractive targets for cryptominers.

Real-World APT Usage of DLL Side-Loading

Nation-state actors have extensively leveraged DLL side-loading as documented by multiple threat intelligence teams:

Threat Actor	Malware	Side-Loaded DLL	Legitimate Application
Stately Taurus	ToneShell	nw.dll, rw32core.dll	PwmTower.exe (password manager)
PKPLUG / Chinese APTs	PlugX RAT	Acrobat.dll	Acrobat.exe (Adobe)
Unknown	AsyncRAT	http_dll.dll	EHttpSrv.exe (ESET)
REvil	Ransomware	mpsvc.dll	MsMpEng.exe (Windows Defender)
Black Basta	C2 Implant	wininet.dll	OneDriveStandaloneUpdater.exe
APT41	DUSTPAN	Trojanized system DLLs	Various Windows binaries

(Sources: Unit 42 — <https://unit42.paloaltonetworks.com/dll-hijacking-techniques/>, Securonix — <https://www.securonix.com/blog/detecting-dll-sideloadng-techniques-in-malware-attack-chains/>, LevelBlue — <https://www.levelblue.com/blogs/levelblue-blog/prevent-detect-contain-levelblue-mdrs-guide-against-black-basta-affiliates-attacks>)

Attack Vector 2: Malware in Cracked / Pirated VST Software

The Economics of VST Piracy

Premium VST plugins range from \$50 to \$500+, creating strong demand for cracked versions. Piracy groups ("warez" / "scene" groups) invest significant effort in bypassing copy protection (iLok, Steinberg eLicenser, PACE, custom DRM). This effort requires a return on investment — which typically comes in the form of **bundled malware**.

As SpiritSeal documents: "The time and effort it takes an independent 3rd party to create a crack for modern VST is extremely significant, as the process of reverse engineering in general is rarely trivial. As such, in exchange for dedicating resources to this task, these

crackers often are expecting some sort of significant return, typically a path to infecting hundreds or thousands of zombie computers that can be hijacked for everything from cryptomining to DDoSing." (Source: <https://spiritseal.github.io/vst-malware-musician/>)

Case Study: LoudMiner (2018–Present)

The most thoroughly documented VST-specific malware campaign is LoudMiner, discovered by ESET Research in 2019 and still active in evolved forms.

Infection Chain:

1. User downloads cracked VST software (Ableton Live, Sylenth1, Nexus, Reaktor 6, Propellerhead Reason, AutoTune, etc.) from sites like `vstcrack[.]com` / `fiestcrack[.]online`.
2. The installer is a legitimate-looking MSI/DMG package (~100+ MB, consistent with real VST sizes).
3. LoudMiner is installed first, before the actual VST plugin software.
4. LoudMiner deploys:
 - VirtualBox (Windows) or QEMU (macOS) virtualization software
 - A Tiny Core Linux 9.0 virtual machine image
 - XMRig Monero cryptocurrency miner configured inside the VM
 - Persistence scripts (Windows services / macOS launch daemons)
 - A CPU monitoring script that stops mining when Activity Monitor / Task Manager is opened

Key Characteristics:

- The VM-based approach makes the miner invisible to host-based antivirus since it runs inside a Linux VM.
- The malware specifically targets music producers because "they need machines with strong processing power and high CPU consumption" — normal high CPU usage from audio processing masks the miner's activity.
- ESET identified 137 trojanized VST applications (95 macOS, 42 Windows) hosted across 29 servers, all frequently updated.

(Sources: BleepingComputer — <https://www.bleepingcomputer.com/news/security/linux-cryptominer-uses-virtual-machines-to-attack-windows-macos/>, SC Media — <https://www.scworld.com/news/making-a-racket-loudminer-malware-cryptojacks-vm-comes-bundled-with-pirated-vst-software>)

Common Malware Types Bundled with Pirated VSTs

Malware Category	Description	Example
Cryptominers	XMRig or similar Monero miners; run persistently, consume CPU/GPU	LoudMiner
Remote Access Trojans (RATs)	Full remote control of victim's machine	PlugX, AsyncRAT, DCRat, Quasar RAT
Infostealers	Steal browser passwords, session cookies, crypto wallets, Discord tokens	Lumma Stealer, Vidar, Stealc, Agent Tesla
Ransomware	Encrypt files and demand payment	Epsilon Red, REvil
Botnets	Enroll machine in DDoS or spam networks	Various
Backdoors	Persistent C2 channel for future exploitation	ToneShell, Cobalt Strike beacons

Piracy Group Distribution Techniques

Based on analysis by [InfoStealers.com](https://www.infostealers.com/article/how-cracks-and-installers-bring-malware-to-your-device/) (Source: <https://www.infostealers.com/article/how-cracks-and-installers-bring-malware-to-your-device/>) and VMRay (Source: <https://www.vmrays.com/malware-phishing-threat-landscape-report-2025-2/>):

1. **YouTube / Social Media Lure:** Tutorial videos showing "how to install [Plugin Name] for free" with download links in descriptions.
2. **File Hosting Services:** Malicious installers hosted on Mediafire, [Mega.nz](https://mega.nz/), or Google Drive to obscure origin.
3. **Password-Protected Archives:** ZIP files require a password, which prevents automated sandbox analysis of the contents on download.
4. **Large File Sizes:** Installers padded to 500MB+ to exceed sandbox upload limits.
5. **Installer Social Engineering:** Installation instructions tell users to "disable antivirus" and "add an exclusion for the install folder" — ostensibly for DRM bypass, actually to prevent malware detection.
6. **Steganography:** Malicious payloads hidden inside WAV audio files or image files, decoded and executed by loader scripts. A March 2026 campaign documented by Eric Parker found malware payloads concealed inside .wav files that were valid audio but contained XOR-encoded executables. (Source: <https://www.youtube.com/watch?v=wFaDDf9LobA>)

Why Antivirus Fails to Detect Malicious VSTs

- VST DLLs are loaded inside trusted DAW processes, inheriting their trust level.
- Crackers employ heavy obfuscation, packing, and encryption of payloads.
- Password-protected archives prevent pre-download scanning.
- VM-based miners (like LoudMiner) run inside a Linux VM, invisible to Windows AV.
- Many malicious VSTs produce valid audio output, making behavioral analysis difficult.

- DAW processes legitimately use high CPU, masking miner activity.

Red Flag Windows API Reference Table

A legitimate VST audio processing plugin should primarily interact with:

- Audio buffer APIs (WASAPI, ASIO, DirectSound wrappers)
- Basic file I/O (for loading presets/samples)
- Memory management (VirtualAlloc for its own audio buffers)
- GUI/windowing APIs (for the plugin editor interface)
- Threading APIs (for real-time audio processing threads)

The following APIs, when found in the Import Address Table (IAT) of a VST .dll or .vst3 file, are **strong indicators of malicious intent** because they serve no legitimate audio processing purpose.

Category 1: Process Injection & Manipulation (CRITICAL — Threat Level: HIGH)

These functions are hallmarks of code injection, process hollowing, and DLL injection techniques. A legitimate audio plugin has zero reason to manipulate other processes.

DLL	Function	Malicious Use
kernel32.dll	CreateRemoteThread	Creates a thread in a remote process — primary technique for DLL injection and shellcode execution in another process.
kernel32.dll	VirtualAllocEx	Allocates memory in a remote process's address space — used to write shellcode or DLL paths before injection.
kernel32.dll	WriteProcessMemory	Writes data into another process's memory — used to copy malicious payloads before triggering execution.
kernel32.dll	ReadProcessMemory	Reads memory from another process — used in credential dumping and process inspection.
kernel32.dll	OpenProcess	Opens a handle to another process with elevated access rights — prerequisite for all injection techniques.
kernel32.dll	SuspendThread	Suspends a thread in another process — used in process hollowing and thread hijacking.
kernel32.dll	ResumeThread	Resumes a suspended thread — paired with SuspendThread in injection chains.
kernel32.dll	SetThreadContext	Modifies register values of a remote thread — used to redirect execution to injected code.
kernel32.dll	GetThreadContext	Reads register state of a remote thread — reconnaissance step before modifying thread context.

DLL	Function	Malicious Use
kernel32.dll	QueueUserAPC	Queues code execution in another thread — alternative injection technique (APC injection).
kernel32.dll	VirtualProtectEx	Changes memory protection in a remote process — used to make injected code executable.
ntdll.dll	NtCreateThreadEx	Low-level thread creation — stealthier alternative to CreateRemoteThread.
ntdll.dll	NtSetInformationProcess	Changes process privilege level or bypasses DEP.
kernel32.dll	CreateToolhelp32Snapshot	Enumerates running processes — reconnaissance for injection target selection.
kernel32.dll	Process32First/ Process32Next	Iterates through process list — used to find specific processes for injection.
kernel32.dll	EnumProcesses	Enumerates all running processes — same purpose as above.

(Sources: Practical Security Analytics — <https://practicalsecurityanalytics.com/threat-hunting-with-function-imports/>, GitHub Gist — <https://gist.github.com/404NetworkError/a81591849f5b6b5fe09f517efc189c1d>, Medium — <https://johndcyber.com/the-most-commonly-exploited-windows-apis-a-security-professionals-guide-d53acf201034>)

Category 2: Networking & C2 Communication (CRITICAL — Threat Level: HIGH)

Audio plugins should **not** make network connections. Exceptions exist for license validation and online preset stores, but the presence of raw socket or HTTP APIs is highly suspicious.

DLL	Function	Malicious Use
wininet.dll	InternetOpenA/ InternetOpenW	Initializes WinINet for HTTP/HTTPS/FTP — start of C2 communication.
wininet.dll	InternetOpenUrlA/ InternetOpenUrlW	Opens a specific URL — downloading payloads or contacting C2.
wininet.dll	InternetReadFile	Reads data from a URL connection — receiving C2 commands or payload data.
wininet.dll	InternetWriteFile	Writes data to an HTTP connection — exfiltrating stolen data.
wininet.dll	HttpSendRequestA/ HttpSendRequestW	Sends an HTTP request — C2 communication or data exfiltration.
wininet.dll	InternetConnectA/ InternetConnectW	Connects to an FTP or HTTP server.
wininet.dll	FtpPutFile	Uploads a file to an FTP server — data exfiltration.
winhttp.dll	WinHttpOpen	Initializes WinHTTP — alternative to WinINet for C2 communication.
winhttp.dll	WinHttpConnect	Establishes connection to an HTTP server.

DLL	Function	Malicious Use
winhttp.dll	WinHttpSendRequest	Sends an HTTP request via WinHTTP.
ws2_32.dll	WSAStartup	Initializes Winsock — starting point for all low-level network activity.
ws2_32.dll	connect	Connects to a remote socket — raw C2 communication.
ws2_32.dll	send / recv	Sends/receives data over raw sockets.
ws2_32.dll	bind / accept	Listens for incoming connections — reverse shell or backdoor listener.
ws2_32.dll	gethostbyname	DNS resolution — resolving C2 server hostname.
ws2_32.dll	gethostname	Retrieves local hostname — victim machine fingerprinting.
ws2_32.dll	inet_addr	Converts IP address string to binary — connecting to hardcoded C2 IP.
urlmon.dll	URLDownloadToFileA/ URLDownloadToFileW	Downloads a file from the internet to disk — dropper/downloader behavior.

Category 3: Registry Manipulation & Persistence (Threat Level: HIGH)

VST plugins should not write to the Windows registry. Registry manipulation is commonly used for persistence (auto-run keys), disabling security features, and storing malware configuration.

DLL	Function	Malicious Use
advapi32.dll	RegOpenKeyExA/ RegOpenKeyExW	Opens a registry key — reading system config or preparing persistence.
advapi32.dll	RegSetValueExA/ RegSetValueExW	Writes a registry value — establishing persistence (Run keys) or modifying system settings.
advapi32.dll	RegCreateKeyExA/ RegCreateKeyExW	Creates a new registry key — establishing persistence.
advapi32.dll	RegDeleteKeyA/ RegDeleteKeyW	Deletes a registry key — covering tracks or disabling security.
ntdll.dll	RtlCreateRegistryKey	Kernel-mode registry key creation — rootkit behavior.
ntdll.dll	RtlWriteRegistryValue	Kernel-mode registry write — rootkit behavior.

Category 4: Service Manipulation (Threat Level: HIGH)

Creating or modifying Windows services is a persistence technique. Audio plugins never need to create services.

DLL	Function	Malicious Use
advapi32.dll	CreateServiceA/ CreateServiceW	Creates a Windows service — persistence mechanism for malware.
advapi32.dll	ControlService	Starts, stops, or modifies a running service.
advapi32.dll	StartServiceCtrlDispatcherA	Registers as a service — indicates the DLL is designed to run as a service.
advapi32.dll	OpenSCManagerA/ OpenSCManagerW	Opens the Service Control Manager — prerequisite for service manipulation.

Category 5: Privilege Escalation & Token Manipulation (Threat Level: HIGH)

DLL	Function	Malicious Use
advapi32.dll	AdjustTokenPrivileges	Enables/disables access privileges — escalation to gain SeDebugPrivilege for injection.
advapi32.dll	OpenProcessToken	Opens the access token of a process — prerequisite for privilege manipulation.
advapi32.dll	LookupPrivilegeValueA	Looks up privilege LUID — used before AdjustTokenPrivileges.
advapi32.dll	ImpersonateLoggedOnUser	Impersonates another user's security context.
advapi32.dll	GetTokenInformation	Queries token details — reconnaissance for privilege escalation.

Category 6: Credential Access & Cryptography (Threat Level: HIGH)

DLL	Function	Malicious Use
advapi32.dll	CryptAcquireContextA/ CryptAcquireContextW	Initializes Windows encryption — may indicate ransomware encryption or C2 traffic encryption.
advapi32.dll	CryptEncrypt/CryptDecrypt	Encrypts/decrypts data — ransomware payload encryption or C2 data obfuscation.
crypt32.dll	CertOpenSystemStore	Accesses system certificate store — certificate theft or SSL interception.
advapi32.dll	LsaEnumerateLogonSessions	Enumerates logon sessions — credential stealing.
samlib.dll	SamIConnect	Connects to SAM database — password hash dumping.
samlib.dll	SamIGetPrivateData	Queries private SAM data — password hash extraction.

Category 7: Keylogging & Surveillance (Threat Level: HIGH)

DLL	Function	Malicious Use
user32.dll	SetWindowsHookExA/ SetWindowsHookExW	Installs a system-wide hook — keylogging and input capture.
user32.dll	GetAsyncKeyState	Checks if a key is pressed — keylogger implementation.
user32.dll	GetKeyState	Gets key status — keylogger implementation.
user32.dll	GetForegroundWindow	Gets active window handle — identifying which app receives keystrokes.
user32.dll	AttachThreadInput	Attaches to another thread's input — spyware behavior.
gdi32.dll	BitBlt	Copies screen graphics — screenshot capture.
user32.dll	GetDC	Gets device context for screen — screenshot capture.
user32.dll	MapVirtualKeyA	Translates virtual-key codes to characters — keylogger output formatting.

Category 8: Anti-Analysis & Evasion (Threat Level: MEDIUM)

DLL	Function	Malicious Use
kernel32.dll	IsDebuggerPresent	Checks if a debugger is attached — anti-analysis technique.
ntdll.dll	NtQueryInformationProcess	Queries process info — anti-debugging (detects debugger presence).
kernel32.dll	OutputDebugStringA	Outputs debug string — can crash certain debuggers (anti-debug).
kernel32.dll	IsWow64Process	Checks if running in WoW64 — environment fingerprinting.
kernel32.dll	GetTickCount	Gets system uptime — sandbox detection (short uptime = sandbox).
kernel32.dll	SetFileTime	Modifies file timestamps — timestomping to conceal malware.
user32.dll	FindWindowA/FindWindowW	Searches for windows by name — detecting debuggers/analysis tools.
kernel32.dll	SfcTerminateWatcherThread	Disables Windows File Protection — tampering with protected system files.

Category 9: File System Reconnaissance (Threat Level: MEDIUM)

While some file operations are legitimate for preset/sample loading, certain patterns are suspicious in a VST context.

DLL	Function	Malicious Use
kernel32.dll	FindFirstFileA/ FindNextFileA	Directory enumeration — ransomware file discovery or data exfiltration target listing.
kernel32.dll	GetWindowsDirectoryA	Gets Windows directory path — locating system files for tampering or malware installation.
kernel32.dll	GetTempPathA	Gets temp directory — common malware staging location.
shell32.dll	ShellExecuteA/ ShellExecuteW	Launches external programs — executing dropped payloads.
kernel32.dll	WinExec	Executes a program — legacy API, rarely used by legitimate modern software.
kernel32.dll	DeviceIoControl	Communicates with device drivers — rootkit communication.

Summary: VST-Sentry Detection Categories

For the VST-Sentry scoring engine, the above APIs are grouped into weighted categories:

Risk Category	Weight	APIs in Category	Rationale
Process Injection	CRITICAL (10 pts each)	CreateRemoteThread, VirtualAllocEx, WriteProcessMemory, OpenProcess, ReadProcessMemory	No legitimate audio purpose whatsoever
Networking	CRITICAL (10 pts each)	All wininet.dll, winhttp.dll, ws2_32.dll, urlmon.dll imports	Audio plugins should not make network connections
Registry/Services	HIGH (7 pts each)	RegSetValueEx, CreateService, ControlService	Persistence mechanisms
Privilege Escalation	HIGH (7 pts each)	AdjustTokenPrivileges, OpenProcessToken, ImpersonateLoggedOnUser	Escalation has no audio purpose
Credential Access	HIGH (7 pts each)	LsaEnumerateLogonSessions, SamlConnect, CertOpenSystemStore	Data theft
Keylogging/Surveillance	HIGH (7 pts each)	SetWindowsHookEx, GetAsyncKeyState, BitBlt	Spyware behavior
Anti-Analysis	MEDIUM (4 pts each)	IsDebuggerPresent, NtQueryInformationProcess, FindWindow	Evasion techniques
Suspicious File Ops	LOW (2 pts each)	GetWindowsDirectory, WinExec, ShellExecute, DeviceIoControl	Context-dependent

Scoring Thresholds (for VST-Sentry implementation):

- Safe: 0–4 points (no concerning imports, or only minor context-dependent ones)
- Suspicious: 5–19 points (some concerning imports that warrant manual review)
- High Risk: 20+ points (strong indicators of malicious intent)

Recommendations and Mitigation Strategies

For Music Producers

1. Never install cracked VST plugins. The risk of cryptominers, RATs, and ransomware is extremely high.
2. Only download plugins from official vendor websites or verified storefronts (Plugin Boutique, Splice, etc.).
3. Verify digital signatures on all DLLs before placing them in plugin directories.
4. Use VST-Sentry to scan all new plugins before installing them into your DAW's plugin folder.
5. Monitor system resource usage — unexplained high CPU when no audio project is active may indicate a miner.
6. Keep DAW and OS updated — patches may address DLL loading vulnerabilities.

For DAW Developers

1. Use full absolute paths in all `LoadLibrary` calls.
2. Implement DLL allowlisting based on cryptographic hashes or signatures.
3. Consider plugin sandboxing — run VST plugins in isolated processes with restricted permissions.
4. Validate plugin signatures during the scan process and warn users about unsigned plugins.
5. Use `LOAD_LIBRARY_SEARCH_APPLICATION_DIR` or `LOAD_LIBRARY_SEARCH_SYSTEM32` flags to constrain DLL search order.

Sources

1. Unit 42 / Palo Alto Networks — "Intruders in the Library: Exploring DLL Hijacking" (Feb 2024) — <https://unit42.paloaltonetworks.com/dll-hijacking-techniques/>
2. SpiritSeal — "VST Plugin Malware Capabilities" (Jan 2023) — <https://spiritseal.github.io/vst-malware-musician/>
3. CrowdStrike — "4 Ways Adversaries Hijack DLLs" (Dec 2022) — <https://www.crowdstrike.com/en-us/blog/4-ways-adversaries-hijack-dlls/>

4. Securonix — "Detecting DLL Sideloaded Techniques in Malware Attack Chains" (Jun 2024) — <https://www.securonix.com/blog/detecting-dll-sideloaded-techniques-in-malware-attack-chains/>
5. Resecurity — "PDFSIDER Malware: DLL Side-Loading for AV/EDR Evasion" (Jan 2026) — <https://www.resecurity.com/blog/article/pdfsider-malware-exploitation-of-dll-side-loading-for-a-v-and-edr-evasion>
6. Dragos — "Suggested Practices to Defend Against DLL Hijacking" — https://hub.dragos.com/hubfs/116-Whitepapers/Dragos_WP_DLL_Hijacking_FINAL.pdf
7. BleepingComputer — "Linux Cryptominer Uses Virtual Machines to Attack Windows, macOS" (Jun 2019) — <https://www.bleepingcomputer.com/news/security/linux-cryptominer-uses-virtual-machines-to-attack-windows-macos/>
8. SC Media — "LoudMiner Malware Cryptojacks VMs, Bundled with Pirated VST Software" (Jun 2019) — <https://www.scworld.com/news/making-a-racket-loudminer-malware-cryptojack-s-vms-comes-bundled-with-pirated-vst-software>
9. InfoStealers.com — "How Cracks and Installers Bring Malware to Your Device" (Jan 2025) — <https://www.infostealers.com/article/how-cracks-and-installers-bring-malware-to-your-device/>
10. VMRay — "Malware & Phishing Threat Landscape Report 2025/2" (Mar 2026) — <https://www.vmrays.com/malware-phishing-threat-landscape-report-2025-2/>
11. Practical Security Analytics — "Threat Hunting with Function Imports" (Nov 2019) — <https://practicalsecurityanalytics.com/threat-hunting-with-function-imports/>
12. GitHub Gist / 404NetworkError — "Windows Functions in Malware Analysis" — <https://gist.github.com/404NetworkError/a81591849f5b6b5fe09f517efc189c1d>
13. John D Cyber / Medium — "The Most Commonly Exploited Windows APIs" (Mar 2024) — <https://johndcyber.com/the-most-commonly-exploited-windows-apis-a-security-professionals-guide-d53acf201034>
14. Google Cloud / Mandiant — "Abusing DLL Misconfigurations" — <https://cloud.google.com/blog/topics/threat-intelligence/abusing-dll-misconfigurations>
15. HarfangLab — "DLL Sideloaded: Solutions to Protect Your Workspace" — <https://harfanglab.io/blog/product/dll-sideloaded-solutions-workspace-security/>
16. LevelBlue — "MDR Guide Against Black Basta Affiliates" (Mar 2025) — <https://www.levelblue.com/blogs/levelblue-blog/prevent-detect-contain-levelblue-mdrs-guide-against-black-basta-affiliates-attacks>
17. PeerJ Computer Science — "Deep Learning Based Sequential Model for Malware Analysis Using Windows API Calls" (Jul 2020) — <https://pmc.ncbi.nlm.nih.gov/articles/PMC7924690/>
18. Deep Instinct — "Malware Evasion Techniques: Process Injection and Manipulation" (Sep 2019) — <https://www.deepinstinct.com/blog/malware-evasion-techniques-part-1-process-injection-and-manipulation>

19. MITRE ATT&CK — "Native API, Technique T1106" — <https://attack.mitre.org/techniques/T1106/>
20. Red Team Diaries / CP Center — "DLL Sideloading: Beyond Classic DLL Hijacking" (Mar 2026) — <https://cp.center/pl/blog/post/dll-sideload-beyond-classic-dll-hijacking-red-team-diaries>